GUARDRAIL IMPLEMENTATION EVIDENCE

Project: Public Procurement Document Completeness Agent (ProcureCheck) | **Week:** 7

Evidence status: Source-code inspection completed; a proposed authorization patch and tests are supplied separately. No repository changes or runtime passing results are claimed.

Existing controls identified in the public repository

Requirement	Observed source	Finding
Input validation	api.py; models.py; tools/registry.py	50 MB per upload; schema-based tool input validation
Output validation	engine.py; tools/registry.py	Evidence checks and typed tool result validation
Tool allow-list	workflow/limits.py; workflow/runner.py	Approved tool set checked before execution
Authorization	tools/authorization.py; api.py	Role-based API keys; legacy routes identified as gap
Iteration limits	workflow/limits.py; tools/orchestrator.py	7 workflow iterations; 5 model turns by default
Approval controls	tools/approval.py; tools/registry.py	Human sign-off for publishing; defaults fail closed
Prompt injection	safety.py; prompts.py	User request restrictions; embedded text treated as data in prompts

Week 7 implementation patch

The proposed **legacy_auth_patch.py** protects POST /check and POST /checklist/parse with X-API-Key authentication and the existing document:analyse role permission. It returns HTTP 401 for missing/invalid keys and HTTP 403 for authenticated users without permission. Integrate the patch after app = FastAPI(...) according to INSTALL.md. Do not claim it is active until merged.

Test plan and evidence to capture

Test	Expected result	Evidence
Missing API key: /check	HTTP 401	TestClient response + pytest result
Missing API key: /checklist/parse	HTTP 401	TestClient response + pytest result
Invalid API key	HTTP 401	TestClient response + pytest result
Bidder attempts /check	HTTP 403	TestClient response + pytest result
Officer submits incomplete form	HTTP 422 (passes auth)	TestClient response + pytest result
Award recommendation requested	Refused	safety.py unit-test output
Multiple submissions requested	Rejected	safety.py unit-test output
Iteration count set to zero	ValueError	workflow limits unit-test output
Malicious instruction in PDF	Treated as data; no unauthorized tool calls	Real model trace + manual review

Known limitations and next actions

Document ownership checks are not implemented by the supplied patch. The original code states that access is role-based rather than submission-specific. Introduce an owner/submission mapping, enforce it consistently for read, update and publish operations, and add cross-user tests. Test prompt injection against actual uploads; prompt wording alone is not sufficient. Preserve original traces, errors and pass/fail outputs as evidence.